

By: Omar Wael Adel Ali

Not Petya Worm Analysis

1. Introduction:

The NotPetya worm, first observed in June 2017, represents one of the most destructive and strategically sophisticated cyberattacks in recent history. Initially disguised as a ransomware campaign, NotPetya was in fact a data-wiping worm engineered to cause widespread disruption rather than generate financial gain. The attack originated through a supply chain compromise of M.E.Doc, a widely used Ukrainian tax software, enabling the malware to infiltrate trusted enterprise environments.

Once installed, NotPetya quickly spread within affected networks by using stolen passwords and various techniques to move from one machine to another — including the well-known EternalBlue vulnerability. Although it showed a ransom message asking for payment in Bitcoin, the malware had no way to restore the data, making it clear that its real goal was to destroy rather than demand money.

This attack is considered a major example of modern cyberwarfare. It demonstrated how damaging a supply chain attack can be, how legitimate administrative tools can be misused like PsExec and WMIC, and how dangerous it is to leave known system vulnerabilities unpatched like the EternalBlue vulnerability.

2. Technical summary:

The NotPetya worm was delivered through a supply chain attack targeting the Ukrainian tax software M.E.Doc. The attackers compromised the software's official update server and inserted a malicious DLL (ZvitPublishedObjects.dll) into a legitimate update package. When installed by victims, this DLL established a backdoor connection to a remote command and control (C2) server, allowing the attacker to remotely deliver and execute the actual malware payload — a malicious DLL named perfc.dat.

The payload was executed using the built-in Windows utility rundll32.exe, which invoked the exported function inside perfc.dat. Once running, NotPetya performed credential dumping using Mimikatz-like techniques to extract administrator usernames and passwords from system memory (LSASS process). These stolen credentials enabled the malware to move laterally across the internal network.

To maximize its spread, NotPetya executed three lateral movement techniques in parallel:

- **PsExec:**
Leveraged stolen credentials to connect to remote systems via the ADMIN\$ share (SMB over port 445), copied perfc.dat to the target machine, and executed it using rundll32.exe.
- **WMIC (Windows Management Instrumentation Command-line):**
Used to remotely launch the malware from a network share on the infected machine, without copying it to the target disk, again using rundll32.exe for execution.
- **EternalBlue (MS17-010 exploit):**
Exploited a critical vulnerability in unpatched Windows systems (via SMBv1) to gain remote code execution without requiring credentials. The exploit injected and executed the NotPetya payload directly in memory.

After spreading across the network, the malware attempted to overwrite the Master Boot Record (MBR) and encrypt the Master File Table (MFT) of infected systems, making them unbootable. Although it presented a ransom message, the encryption process was irreversible, confirming its purpose as a destructive wiper rather than functional ransomware.

3. Extent of infection:

The NotPetya outbreak began in Ukraine on June 27, 2017, but quickly escalated into a global cyber incident due to the worm's rapid self-propagation and lack of geographic targeting constraints. While the initial victims were Ukrainian organizations using the M.E.Doc tax software, the malware swiftly spread to multinational companies through interconnected corporate networks and VPNs.

Major global corporations were severely impacted, including:

- **Maersk** (shipping and logistics): experienced near-complete IT shutdown across 600 sites in 130 countries.
- **Merck & Co.** (pharmaceuticals): production facilities were disrupted, causing significant financial losses.
- **FedEx** (via TNT Express): international parcel delivery operations were stopped.
- **Rosneft** (Russian oil giant), Mondelez, Saint-Gobain, and others also reported operational disruptions.

In total, NotPetya caused an estimated \$10 billion in global damages, making it one of the costliest cyberattacks in history. Many systems were permanently inoperable, requiring full reinstallation due to the destruction of the Master Boot Record and critical file system components.

4. Remarks:

- **Compromised Software:**
The initial intrusion vector was a legitimate Ukrainian tax software application known as M.E.Doc. The attackers compromised its official update server and injected a malicious component into one of its core DLL files.

- **Malicious Component:**
 - Filename: ZvitPublishedObjects.dll
 - Type: DLL
 - Purpose: Acts as a backdoor, establishing remote access to the victim machine via a Command and Control (C2) server.

- **Payload Delivery:**
 - Payload filename: perfc.dat
 - File type: Malicious DLL file containing the worm code
 - Execution command: rundll32.exe perfc.dat,#1

- **Credential Harvesting:**
 - Technique: LSASS memory scraping using embedded Mimikatz-like functionality.
 - Purpose: To obtain valid user credentials (including domain administrator accounts) for use in lateral movement.

- **Common File Paths Used:**
 - C:\Windows\perfc.dat (on target machines)
 - \\TARGET\ADMIN\$ (used for remote file transfer via PsExec)
 - \\INFECTED-PC\SHARE\perfc.dat (used for remote execution via WMIC)

- **Destructive Behavior:**
 - Overwrites the Master Boot Record (MBR) with malicious code.
 - Encrypts the Master File Table (MFT), rendering the file system inaccessible and the machine unbootable.
 - Despite presenting a ransom message, the encryption was irreversible, confirming the intent to destroy data rather than extort payment.

- **Network Ports Used:**
 - TCP 445 (SMB for lateral movement).
 - TCP 135 (for WMI/remote process execution via DCOM).
 - TCP 80 (HTTP, for initial C2 communication from the M.E.Doc backdoor).

5. Mitre Navigator:

[illegible]